

EXTRAHOP

A Report by Pedapati Prem Kumar

Introduction: ExtraHop Network Detection and Response (NDR) is a cybersecurity solution designed to provide real-time visibility into network traffic and detect advanced threats. It uses machine learning and behavioral analytics to identify suspicious activities, such as ransomware, insider threats, and lateral movement, across hybrid and cloud environments. By analyzing encrypted and unencrypted traffic without requiring decryption, it ensures strong security while maintaining performance. ExtraHop NDR integrates with existing security tools, enabling faster threat investigation and response. Overall, it helps organizations enhance their security posture by delivering actionable insights and reducing the time to detect and remediate cyber threats effectively.

Features of EXTRAHOP NDR:

The ExtraHop Network Detection and Response (NDR) interface can be visualized as a hub-and-spoke graph where Overview sits at the center, connecting to Dashboards, Detections, Assets, Records, and Packets. Each node represents visibility layers, collectively enabling monitoring, analysis, investigation, and deep packet-level forensic insights across network environments.

1. Overview

2. Dashboards

3. Detections

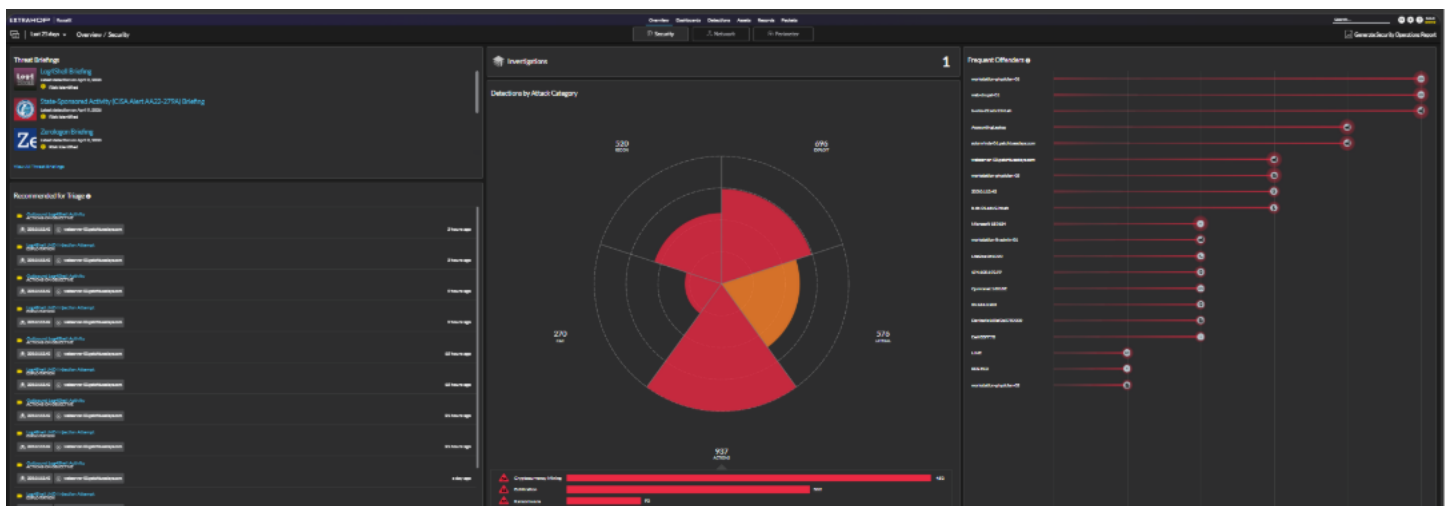
4. Assets

5. Records

6. Packets

1. Overview:

A. Security:

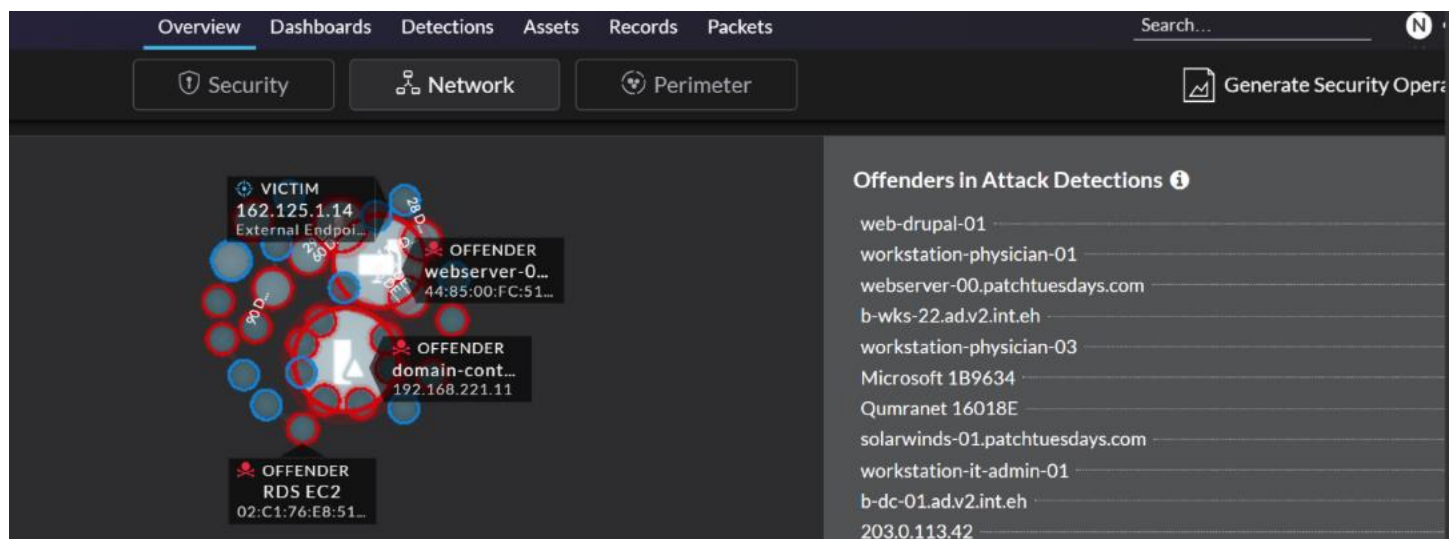


Overview Of EXTRAHOP (security's)

The Overview (Security) section in ExtraHop Network Detection and Response (NDR) provides a centralized, real-time snapshot of an organization's security posture. From the image, it highlights Threat Briefings, which inform users about major vulnerabilities like Log4Shell and Zero logon, helping teams stay aware of current risks and exposures.

It also includes Investigations and Detections by Attack Category, showing metrics such as reconnaissance, exploitation, lateral movement, and command-and-control activity. Additionally, Recommended for Triage prioritizes urgent threats, while Frequent Offenders identifies compromised systems. This overview helps security teams quickly detect, prioritize, and respond to threats efficiently.

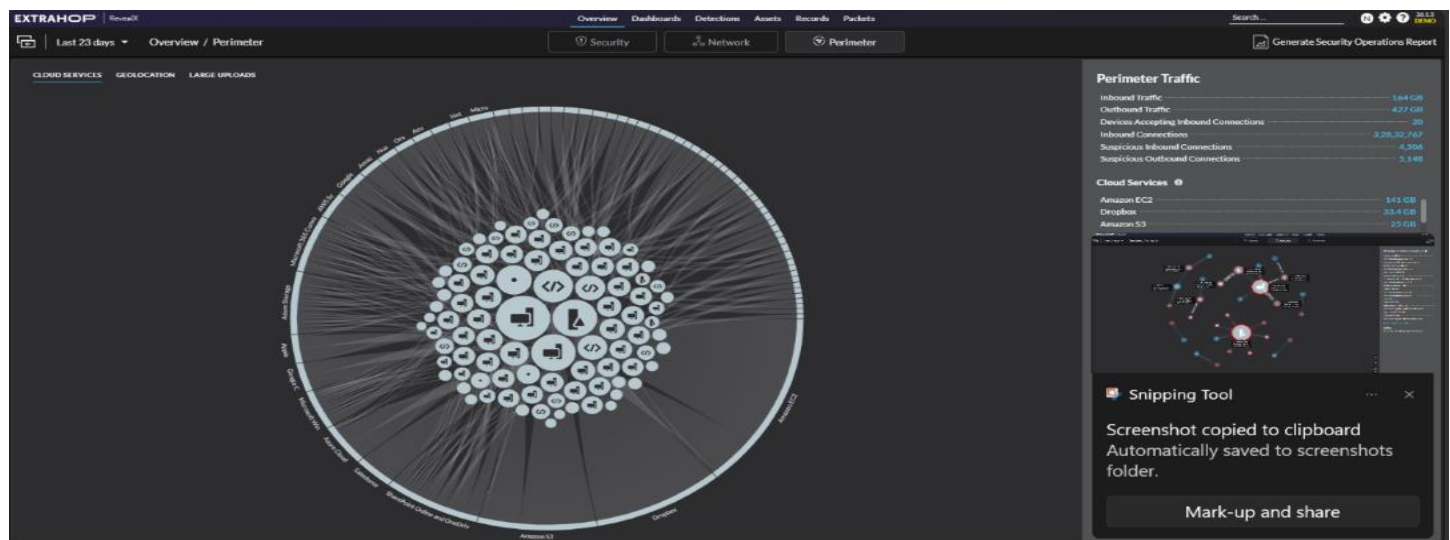
B. Network:



The **Overview (Network)** feature in ExtraHop Network Detection and Response (NDR) visualizes real-time device interactions through an interactive topology map, highlighting offenders, victims, and connections to help analysts trace attack paths, detect anomalies, and understand network behavior efficiently.

- a. **Topology Visualization:** Displays connected devices and communication paths clearly.
- b. **Offender & Victim Identification:** Highlights compromised and targeted systems.
- c. **Attack Detection Insights:** Shows suspicious activities and detection counts.

C. Perimeter:



Perimeter Of Overview

The Perimeter section visualizes external and internal network interactions, highlighting inbound and outbound traffic volumes, suspicious connections, and cloud service usage. It provides a holistic view of perimeter activity, enabling analysts to detect anomalies, assess risks, and prioritize incident response effectively.

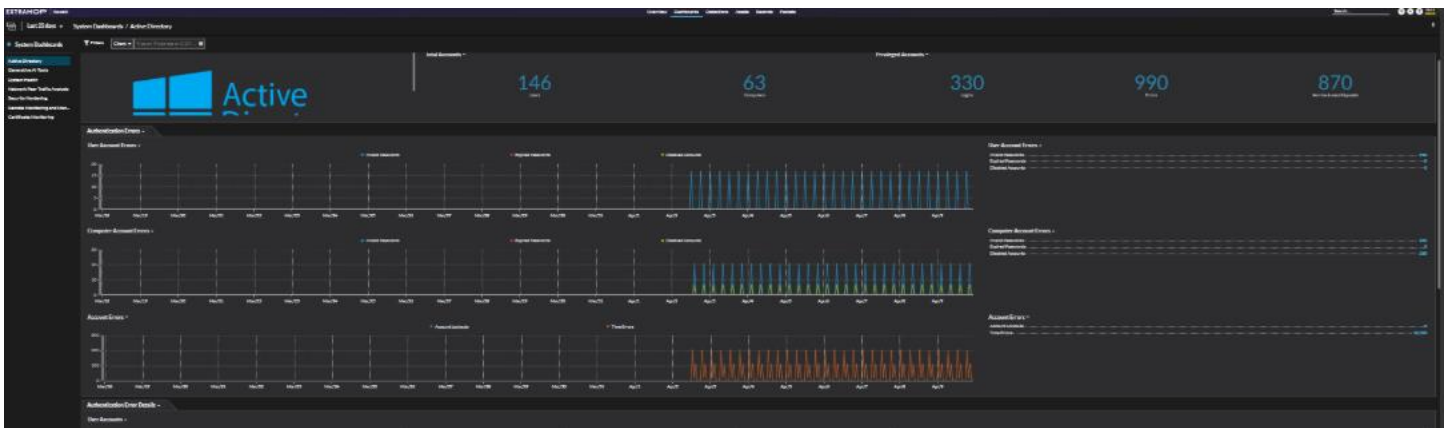
a. Inbound Traffic: Shows the total data entering the network. High inbound volumes or unusual spikes may indicate external scanning, brute-force attempts, or malicious payload delivery.

b. Suspicious Connections: Flags inbound and outbound connections that deviate from normal patterns. These are critical indicators of potential intrusions, malware activity, or unauthorized access attempts.

c. Devices Accepting Connections: Lists internal assets exposed to external communication. Monitoring these helps identify vulnerable endpoints and assess exposure to perimeter threats.

d. Cloud Services Usage: Breaks down traffic volumes across services like Amazon EC2, Dropbox, and Amazon S3. This helps track legitimate business activity versus potential misuse of cloud platforms for data movement.

2.DashBoards:



Dashboards of EXTRAHOPa

System dashboards are centralized monitoring panels that provide visibility into different aspects of IT infrastructure, security, and performance. They consolidate metrics, logs, and alerts into structured views, enabling administrators to quickly assess system health, detect anomalies, and make informed decisions.

a. Active Directory: Tracks user and computer account activity, authentication attempts, and errors. Helps identify password issues, disabled accounts, and potential misuse of privileged accounts.

b. Generative AI Tools: Monitors usage of AI-driven applications, ensuring compliance, performance optimization, and detection of unusual activity patterns.

c. System Health: Provides insights into CPU, memory, storage, and application performance. Useful for proactive maintenance and capacity planning.

d. Network Peer Traffic Analysis: Visualizes communication between devices and services. Helps detect abnormal traffic flows, lateral movement, or unauthorized connections.

e. Security Hardening: Highlights vulnerabilities, misconfigurations, and compliance gaps. Supports remediation efforts to strengthen overall security posture.

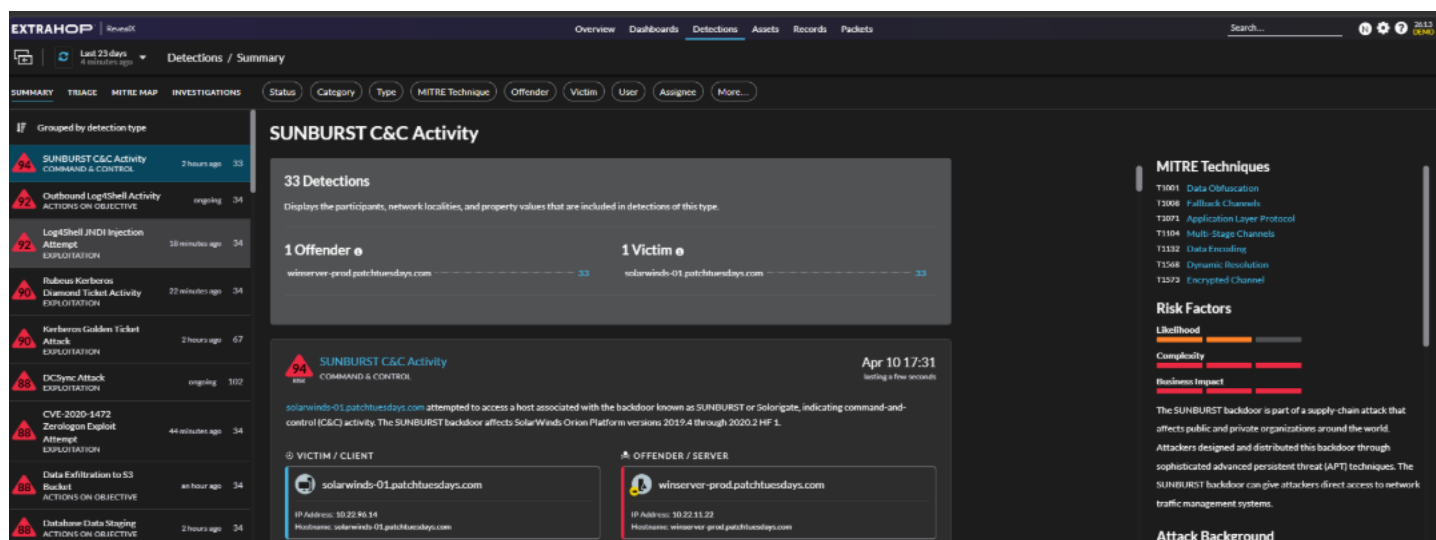
f. Remote Monitoring and Management: Enables oversight of distributed systems and endpoints. Facilitates patching, updates, and troubleshooting across remote environments.

g. Certificate Monitoring: Tracks SSL/TLS certificates, expiration dates, and validity. Prevents outages and security risks due to expired or misconfigured certificates.

3. Detections:

A. Summary:

The Summary feature in ExtraHop NDR provides a high-level overview of detections, including participants, risk scores, and threat context. It helps analysts quickly understand attack behavior, assess severity, and prioritize investigations by combining network insights with MITRE mapping and risk analysis.



Summary of Detection interface

The Summary feature in ExtraHop NDR provides a high-level overview of detections, including participants, risk scores, and threat context. It helps analysts quickly understand attack behavior, assess severity, and prioritize investigations by combining network insights with MITRE mapping and risk analysis.

1. **Detection Overview Panel:** The Summary view displays the total number of detections for a specific threat type, helping analysts understand the scale and frequency of suspicious activity. By grouping similar detections together, it provides a consolidated view that reduces alert noise and highlights patterns across the network.

2. **Participants (Offender & Victim):** This section identifies the offender (source) and victim (target) systems involved in the detection, clearly showing who initiated the suspicious activity and who is affected. It also includes interaction counts, which help reveal repeated communication patterns that may indicate persistent threats like command-and-control activity.

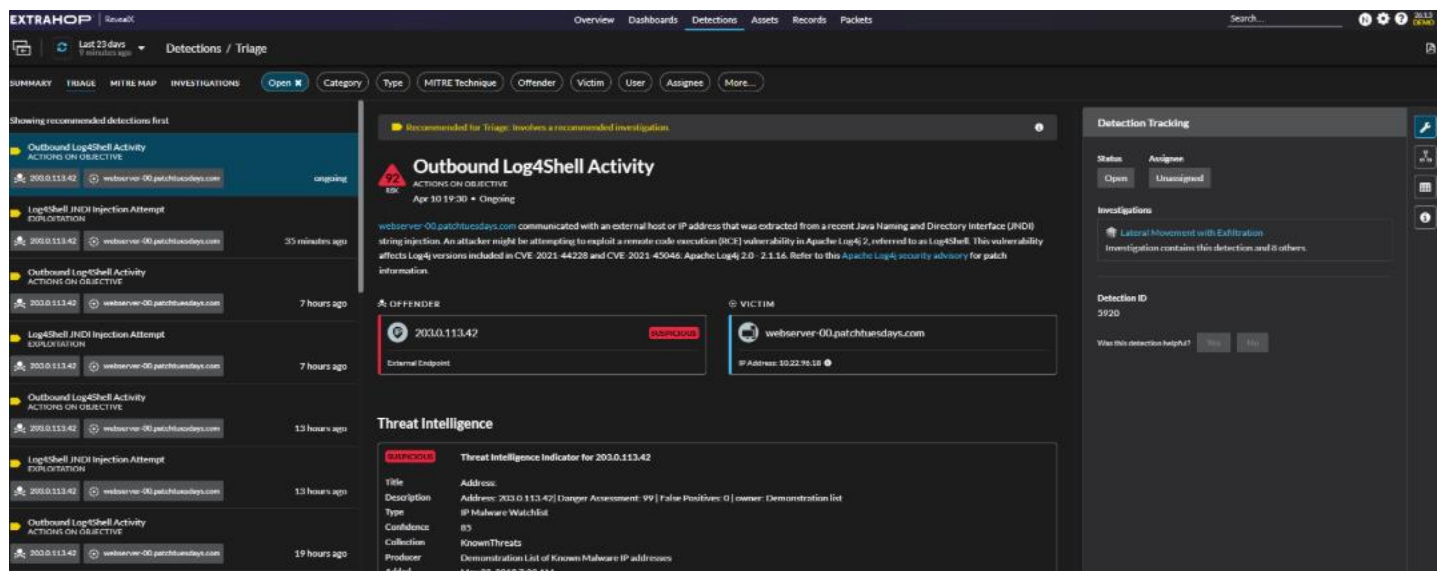
3. **Detection Card Details:** Each detection is summarized with key attributes such as risk score, timestamp, classification, and a brief description of the threat. This allows analysts to quickly assess severity, understand the nature of the attack, and prioritize response actions without needing immediate deep analysis.

4. **Victim & Offender Details:** The Summary provides detailed system-level information including hostnames and IP addresses for both the offender and victim. This enables quick identification of affected assets and supports further investigation or response actions such as isolating compromised systems.

5. **MITRE Techniques Mapping:** Detections are mapped to relevant MITRE ATT&CK techniques, helping analysts understand the tactics and methods used by attackers in a standardized framework. This mapping improves threat analysis, supports threat hunting, and aligns detection insights with known adversary behaviors.

6. **Risk Factors:** The risk factors section evaluates the detection based on likelihood, complexity, and business impact, providing a comprehensive view of the threat’s severity. These metrics help analysts prioritize incidents effectively by identifying which threats pose the greatest risk to the organization.

B. Triage:



Triage of Detection interface

The Triage feature in ExtraHop NDR helps analysts prioritize and investigate detections efficiently by providing detailed alert information, threat intelligence, and workflow tracking. It streamlines incident response by highlighting critical threats, linking investigations, and enabling effective management of security events.

1. **Detection List & Prioritization:** The Triage view presents a list of detections, often sorted to show recommended or high-priority alerts first, enabling analysts to focus on the most critical threats. It includes timestamps, categories, and status indicators like ongoing or recent, helping quickly assess urgency and workflow.

2. **Detection Details Overview:** When a detection is selected, it provides a detailed overview including the risk score, detection type, and activity timeline, offering immediate insight into the severity and nature of the threat. This helps analysts quickly understand what kind of attack is occurring without needing to navigate away.

3. **Offender & Victim Identification:** The Triage panel clearly highlights the offender (external or internal source) and the victim (target system) involved in the activity, along with labels such as “suspicious.” This enables quick identification of compromised or risky entities and supports faster containment decisions.

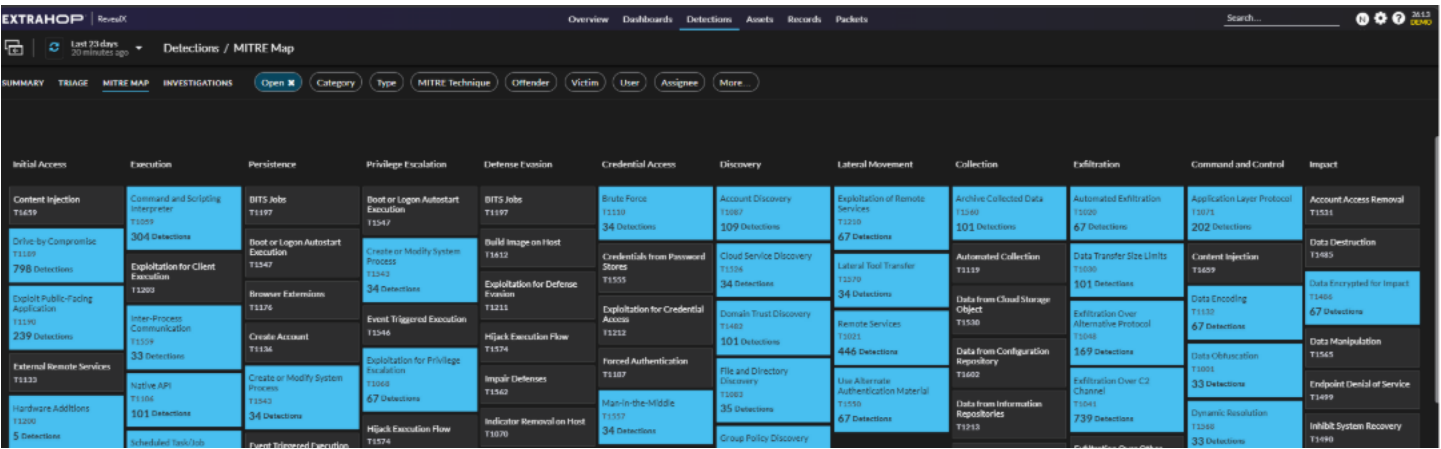
4. **Threat Intelligence Integration:** This section enriches detections with threat intelligence data, such as IP reputation, confidence scores, and malware watchlists. It provides context about whether an entity is known to be malicious, helping analysts validate threats and reduce false positives.

5. **Detection Tracking & Workflow:** The Triage view includes workflow features like status (open/closed), assignment, and investigation linkage, allowing teams to manage and track incidents efficiently. This ensures accountability and helps coordinate response efforts across analysts.

6. **Investigation Context:** Detections are often linked to broader investigations or attack chains, showing how a specific alert fits into a larger security incident. This helps analysts understand the full scope of an attack, such as lateral movement or data exfiltration.

7. **Actionable Insights & Recommendations:** The system may highlight detections as recommended for triage, guiding analysts toward alerts that require immediate investigation. This reduces decision fatigue and ensures that critical threats are addressed promptly with informed actions.

C. MITRE Map:



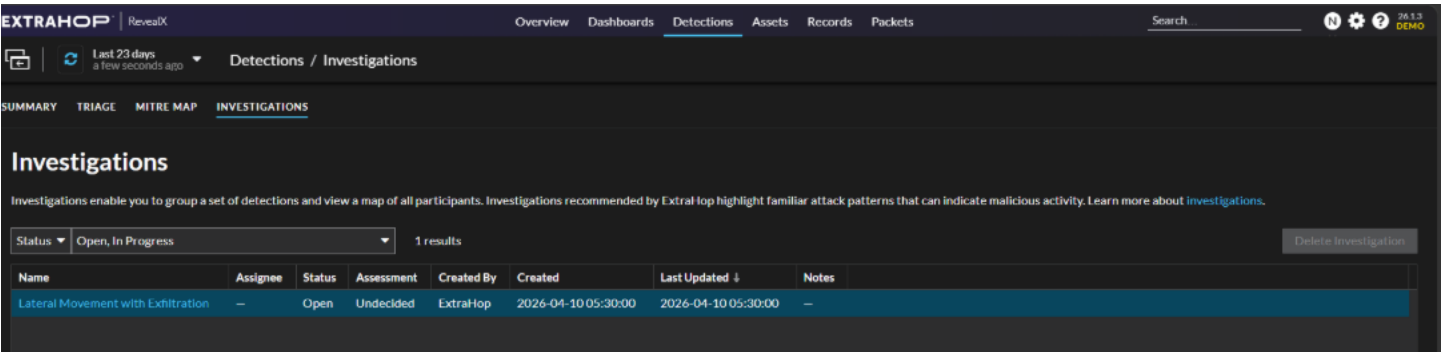
MITRE Map of detection Interface

The MITRE Map in ExtraHop NDR visualizes detections across the MITRE ATT&CK framework, helping analysts understand attacker tactics and techniques. It highlights detection coverage, identifies gaps, and enables tracking attack progression, improving threat analysis, security posture, and incident response efficiency.

- MITRE ATT&CK Framework Overview:** The MITRE Map visualizes detections aligned with the MITRE ATT&CK framework, organizing them into tactics such as Initial Access, Execution, and Exfiltration. This structured layout helps analysts understand where an attack fits within the overall attack lifecycle and identify adversary behavior patterns.
- Tactics and Techniques Representation:** Each column represents a tactic, and within it are multiple techniques that attackers use to achieve their goals. The map highlights which techniques are detected in the environment, making it easier to see how attackers progress through different stages of an attack.
- Detection Volume & Heat Mapping:** The MITRE Map uses color intensity and detection counts to indicate how frequently certain techniques are observed. Higher counts and brighter highlights help analysts quickly identify heavily targeted areas, signaling potential attack focus or weaknesses in the network.
- Coverage and Visibility Analysis:** This view allows analysts to evaluate security coverage across all MITRE techniques, identifying which areas have strong detection visibility and which may lack monitoring. Gaps in the map can reveal blind spots that require improved detection rules or security controls.
- Threat Progression Understanding:** By observing multiple techniques across different tactics, analysts can trace attack progression from entry to impact, such as moving from initial access to lateral movement and exfiltration. This helps in understanding the full scope of multi-stage attacks.
- Correlation with Detections:** Each technique is linked to underlying detections, allowing analysts to drill down into specific alerts associated with that behavior. This connection provides a seamless transition from high-level visualization to detailed investigation.

7. **Strategic Security Insights:** The MITRE Map provides strategic insights by aligning detections with known adversary tactics and techniques, improving threat intelligence and reporting. It helps organizations strengthen defenses by focusing on frequently targeted or high-risk techniques.

D. Investigations:



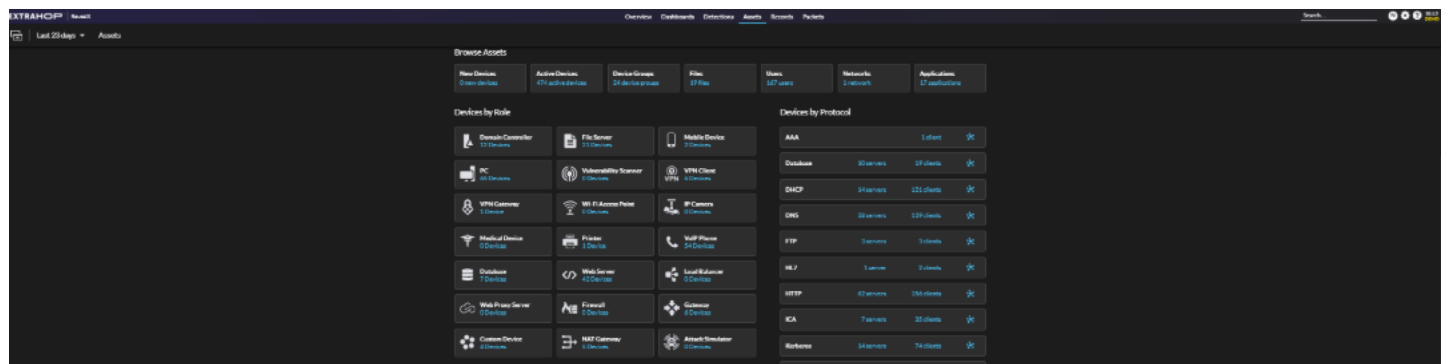
Investigations of Detection interface

- 1. **Investigation Overview:** The Investigations view allows analysts to group multiple related detections into a single case, providing a unified view of suspicious activity. This helps in understanding whether individual alerts are part of a larger coordinated attack rather than isolated incidents.
- 2. **Attack Pattern Identification:** Investigations highlight common attack patterns, such as lateral movement or data exfiltration, by correlating multiple detections. This enables analysts to recognize complex, multi-stage attacks that might not be obvious when viewing alerts individually.
- 3. **Status and Workflow Management:** Each investigation includes statuses like Open or In Progress, along with assignment and assessment fields to track progress. This helps teams manage incident response efficiently and ensures accountability throughout the investigation lifecycle.
- 4. **Participant Mapping:** Investigations provide visibility into all involved entities, including affected systems and external endpoints, helping analysts see the full scope of the attack. This mapping makes it easier to trace how the threat spreads across the network.
- 5. **Timeline and Activity Tracking:** The feature includes timestamps such as creation time and last updated time, allowing analysts to track how an investigation evolves. This chronological view helps in understanding the sequence of events and identifying key moments in the attack.
- 6. **Correlation of Detections:** Multiple detections are linked within a single investigation, enabling analysts to correlate events and uncover relationships between them. This reduces fragmentation and provides a clearer picture of the overall security incident.
- 7. **Centralized Case Management:** Investigations act as a centralized workspace where analysts can review, manage, and document security incidents. This improves collaboration, streamlines analysis, and supports better decision-making during incident response.

4. Assets:

The Assets feature in ExtraHop provides real-time visibility into all network devices, categorizing them by role and protocol. It enables efficient search, analysis, and monitoring of assets, helping analysts understand network behavior, detect anomalies, and support faster security investigations.

1. **Asset Discovery Overview:** The Assets view provides a centralized inventory of all devices detected across the network, including endpoints, servers, and IoT devices. It continuously discovers and updates assets using network traffic analysis, ensuring real-time visibility without relying on agents.
2. **AI Search Assistant:** The AI-powered search assistant allows analysts to quickly find devices by asking natural language questions or using suggested queries. This simplifies asset discovery and enables faster identification of systems involved in suspicious or specific network activities.



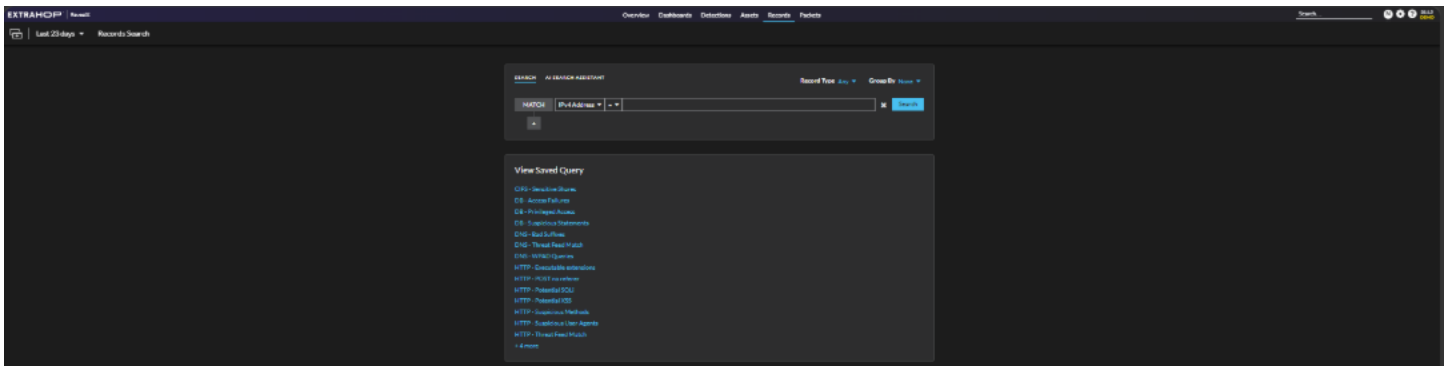
Assets Panel of ExtraHop

3. **Asset Categorization:** Assets are grouped into categories such as devices, device groups, files, users, networks, and applications, making navigation easier. This structured organization helps analysts quickly locate relevant resources and understand relationships between different entities.
4. **Devices by Role:** The platform classifies devices based on their roles, such as domain controllers, file servers, VPN clients, or database servers. This role-based grouping helps analysts understand the function of each asset and identify critical systems within the network.
5. **Devices by Protocol:** Assets are also organized based on the network protocols they use, such as HTTP, DNS, LDAP, or RDP. This allows analysts to monitor communication patterns and detect anomalies related to specific protocols or services.
6. **Asset Relationships and Visibility:** The Assets view provides insights into how devices interact with each other across the network. This visibility helps analysts trace communication paths, identify unusual connections, and understand potential attack surfaces.
7. **Security and Investigation Support:** Assets play a critical role in investigations by providing context about affected systems and their behavior. This information helps analysts correlate detections with specific devices, improving threat analysis, and enabling faster incident responses.

5. Records:

The Records feature in ExtraHop provides detailed, transaction-level visibility into network activity, enabling advanced search, filtering, and forensic analysis. It helps analysts detect anomalies, investigate threats, and monitor communication patterns effectively for improved security and incident response.

1. **Records Search Overview:** The Records view allows analysts to search and analyze transaction-level network data, providing deep visibility into communications across the network. It enables precise filtering using fields like IP address, protocol, or record type to quickly locate relevant activity.
2. **Advanced Search and Query Builder:** The search interface supports custom queries and match conditions, allowing analysts to refine results based on specific criteria. This flexibility helps in isolating suspicious behavior and performing detailed forensic analysis efficiently.

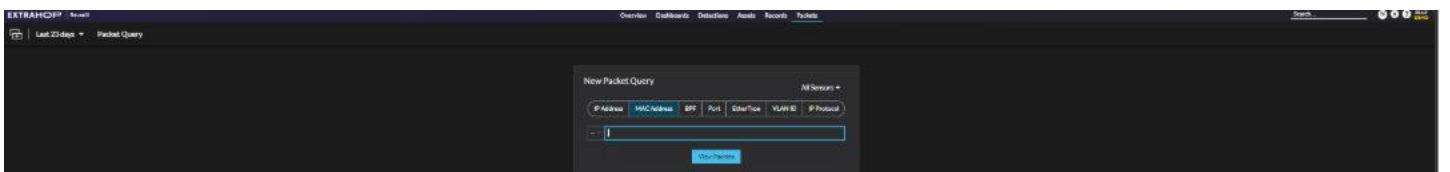


Records Of ExtraHop

3. **Saved Queries and Templates:** The platform provides predefined and saved queries such as DNS threats, HTTP anomalies, or database access patterns. These ready-to-use templates speed up investigations and help analysts quickly identify common security issues.
4. **Protocol-Level Visibility:** Records provide detailed insights into network protocols like HTTP, DNS, SMB, and more, showing how data flows between systems. This helps analysts detect anomalies, misuse, or malicious activity at the communication level.
5. **Data Filtering and Grouping:** Analysts can organize results by record type, grouping, and filters, making it easier to interpret large volumes of data. This structured approach improves clarity and helps focus on the most relevant information.
6. **Forensic Investigation Support:** The Records feature enables deep forensic analysis by providing raw transaction data, allowing analysts to trace events and reconstruct attack scenarios. This level of detail is critical for understanding how a breach occurred.
7. **Security Monitoring and Insights:** By continuously analyzing records, analysts gain real-time insights into network behavior and potential threats. This supports proactive monitoring, faster detection of anomalies, and improved overall security posture.

6. Packets:

The Packets feature in ExtraHop provides deep packet-level visibility, enabling precise filtering and analysis of raw network traffic. It supports forensic investigations, detects hidden threats, and enhances incident response by allowing analysts to inspect communication details at the lowest level.



Packet Interface Of ExtraHop

1. **Packet Query Overview:** The Packets view allows analysts to perform packet-level queries to retrieve raw network traffic for detailed inspection. It provides the deepest level of visibility, enabling precise analysis of communications between systems.
2. **Advanced Packet Filtering:** Analysts can filter packets using parameters such as IP address, MAC address, port, VLAN ID, and protocol, allowing highly targeted searches. This helps isolate specific traffic flows and focus on suspicious or relevant data.

3. **Deep Packet Inspection (DPI)**: The feature supports deep packet inspection, enabling analysts to examine the actual contents of network packets. This is crucial for identifying hidden threats, payload anomalies, or malicious data embedded within traffic.

4. **Protocol-Level Packet Analysis**: Packets can be analyzed based on specific protocols, helping analysts understand how data is transmitted and identify irregularities. This is especially useful for detecting protocol misuse or unusual communication patterns.

5. **Real-Time and Historical Analysis**: The Packets feature supports both real-time and historical packet analysis, allowing analysts to investigate ongoing threats as well as past incidents. This flexibility enhances both proactive monitoring and retrospective investigations.

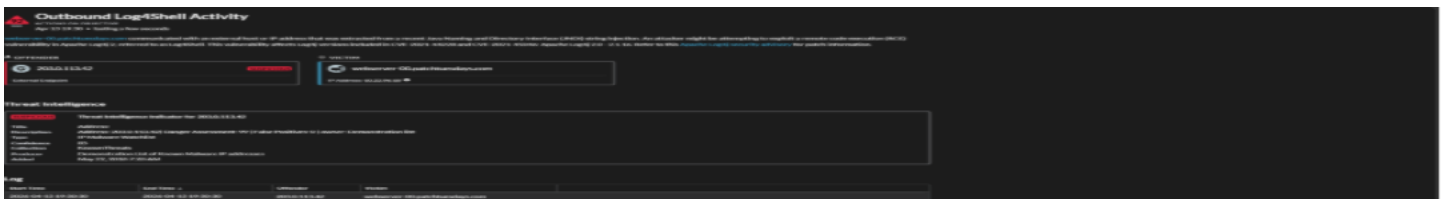
6. **Forensic Investigation Capability**: Packet data provides forensic-level evidence, enabling analysts to reconstruct exact network events and validate detections. This level of detail is essential for confirming attacks and understanding their execution.

7. **Incident Response Support**: By providing raw packet visibility, this feature helps analysts take informed response actions, such as identifying compromised data or attack vectors. It strengthens overall incident response and improves threat mitigation strategies.

Find 5 detection in High score and write a detailed report on any 1 detection as per your understandings:

1. Outbound Log4Shell Activity:

The detection highlights **Outbound Log4Shell Activity** with a high-risk score of 92, indicating a critical threat where the internal web server communicates with a suspicious external IP following a JNDI injection attempt. This suggests a possible remote code execution (RCE) exploit and potential system compromise.



Outbound Log4Shell Activity

1. Detection Name: Outbound Log4Shell Activity

2. Risk Score: 92 (Critical)

3. Category: Actions on Objective

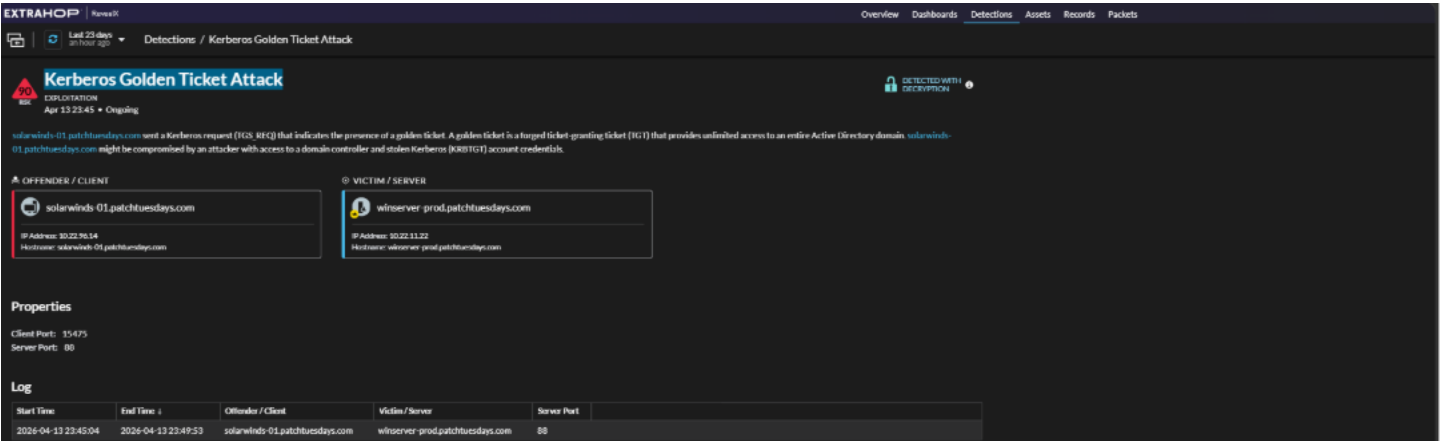
4. Timestamp: Apr 13, 19:30

5. Duration: Few seconds

6. Protocol: HTTP / JNDI-based Communication

2. Kerberos Golden Ticket Attack:

A **Golden Ticket attack** involves forging a Kerberos Ticket Granting Ticket (TGT) using stolen **KRBTGT account credentials**. This allows attackers to impersonate any user and gain unrestricted access across the Active Directory domain.



Kerberos Golden Ticket Attack

- 1. **Detection Type:** Kerberos Golden Ticket Attack
- 2. **Category:** Exploitation
- 3. **Status:** Ongoing (detected with decryption)
- 4. **Timestamp:** April 13, 2026, 23:45

A. Offender (Client)

Hostname: solarwinds-01.patchtuesdays.com
IP Address: 10.22.96.14

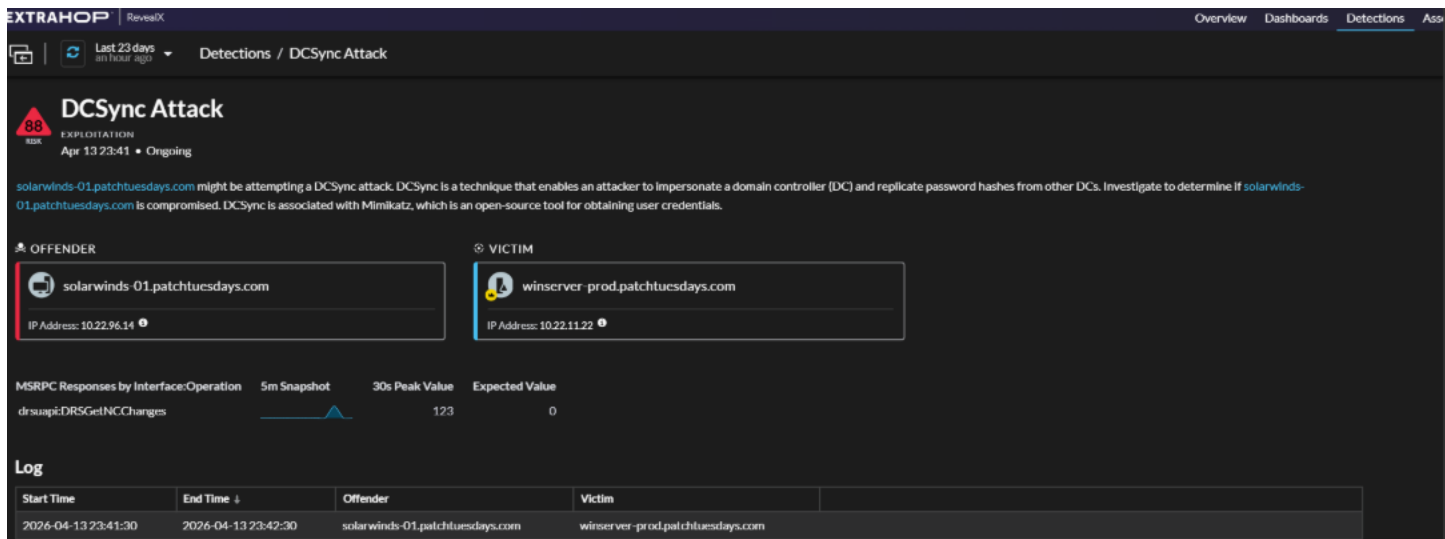
Behavior: Sent multiple suspicious TGS_REQ requests without corresponding AS_REP messages (indicating forged tickets).

B. Victim (Server)

Hostname: winsrvr-prod.patchtuesdays.com
IP Address: 10.22.11.22
Role: Domain Controller (critical infrastructure target).

3. DCSync Attack:

A DCSync attack allows an adversary to impersonate a domain controller and request replication of password hashes from other DCs. This technique is commonly executed using Mimikatz and is a precursor to full domain compromise.



DCSync Attack.

1. **Detection Type:** DCSync Attack

2. **Category:** Exploitation

3. **Risk Score:** 88 (High)

4. **Status:** Ongoing

5. **Timestamp:** April 13, 2026, 23:41

Offender (Client):

Hostname: solarwinds-01.patchtuesdays.com

IP Address: 10.20.96.14

Behavior: Initiated suspicious MSRPC drsuapi:DRSGetNCChanges requests (123 observed in 5 minutes).

Expected Value: 0 (indicating this activity is abnormal).

Victim (Server):

Hostname: winserver-prod.patchtuesdays.com

IP Address: 10.22.111.12

Role: Domain Controller (critical infrastructure target).

4. CVE-2020-1472 ZeroLogon Exploit Attempt:

CVE-2020-1472, known as ZeroLogon, exploits a flaw in Microsoft's Netlogon protocol allowing attackers to impersonate domain controllers. By sending crafted authentication requests, it resets the domain controller password, enabling full network compromise. Detection shows privilege-escalation attempts from unauthorized hosts targeting critical infrastructure systems.

EXTRAHOP

RevealX

OverviewDashboardsDetectionsAss

Last 23 days
an hour ago

Detections / CVE-2020-1472 Zerologon Exploit Attempt

88

EXPLOITATION

Apr 13 19:03 • lasting a few seconds

b-wks-22.adv2.int.eh

b-wks-22.adv2.int.eh sent several requests to establish a Netlogon session with a domain controller and change the domain controller password. This activity matches attempts to exploit a privilege escalation vulnerability referred to as Zerologon. This vulnerability only affects versions included in CVE-2020-1472: Windows Server 2008, Windows Server 2012, Windows Server 2016, Windows Server 2019, and Windows Server, version 1903, 1909, and 2004.

OFFENDER

b-wks-22.adv2.int.eh

IP Address: 192.168.222.106

VICTIM

b-dc-01.adv2.int.eh

IP Address: 192.168.222.11

Log

Start Time	End Time	Offender	Victim
2026-04-13 19:03:30	2026-04-13 19:04:00	b-wks-22.adv2.int.eh	b-dc-01.adv2.int.eh

Servers

View all the servers that received netlogon:NetrServerPasswordSet2 requests

Records	Server IP	Host	netlogon:NetrServerPasswordSet2 Requests
Q	192.168.222.11	b-dc-01.adv2.int.eh	1

CVE-2020-1472 Zerologon Exploit Attempt

1. Detection Type: Zerologon Exploit Attempt (CVE-2020-1472)

2. Category: Exploitation

3. Risk Score: 88 (High)

4. Status: Ongoing (short burst activity)

5. Timestamp: April 13, 2026, 19:03 – 19:04

Offender (Client)

IP Address: 192.168.222.106

Behavior: Attempted to establish a

Netlogon session and issue a NetrServerPasswordSet2 request Hostname: b-wks-22.adv2.int.eh to change the DC's password.

Victim (Server)

Hostname: b-dc-01.adv2.int.eh

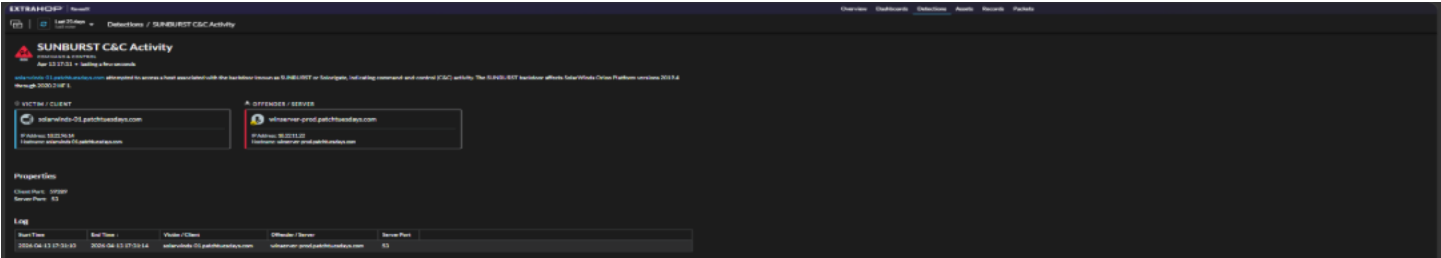
IP Address: 192.168.222.11

Role: Domain Controller (critical infrastructure target).

5. SUNBURST C&C Activity:

Summary:The detection identifies SUNBURST Command-and-Control (C2) activity, indicating a potential compromise linked to the SolarWinds supply chain attack. A victim system attempted communication with a suspicious server, suggesting possible backdoor activity and unauthorized external communication.

2. Detection Overview:



- 1 .Field: Details
- 2. Detection Name: **SUNBURST C&C Activity**
- 3. Risk Score: **94 (Critical)**
- 4. Category: Command & Control
- 5. Timestamp: Apr 13, 17:31
- 6. Duration: Few seconds
- 7. Protocol: **DNS (Port 53)**

3. Affected Entities:

Role	Hostname	IP Address	Description
Victim (Client)	solarwinds-01.patchtuesdays.com	10.22.96.14	Internal system initiating request
Offender (Server)	winserver-prod.patchtuesdays.com	10.22.11.22	Suspicious C2 endpoint

4. Network Activity Summary:

Attribute	Value
Client Port	59289
Server Port	53 (DNS)
Protocol	UDP
Activity Type	DNS Requests
Behavior	Repeated queries to suspicious domain

5. Packet-Level Analysis:

Time	Source IP	Destination IP	Protocol	Source Port	Destination Port
17:31:10	10.22.96.14	10.22.11.22	UDP	59289	53
17:31:10	10.22.96.14	10.22.11.22	UDP	59290	53
17:31:14	10.22.96.14	10.22.11.22	UDP	59289	53

6. Observations:

- 1. The detected activity shows **short-duration but repeated DNS communication**, which is typical of stealthy command-and-control behavior designed to avoid detection.

- 2. The use of **randomized domain names (DGA patterns)** indicates an advanced evasion technique commonly associated with sophisticated malware like SUNBURST.
- 3. Communication occurs over **standard DNS port (53)**, which is often allowed in networks, making it an effective covert channel for attackers.
- 4. The interaction between the victim and offender appears **automated rather than user-initiated**, suggesting the presence of a backdoor or malicious process.
- 5. Despite low data transfer, the **pattern and intent of communication are highly suspicious**, emphasizing that even minimal traffic can indicate critical threats.

7. Log & Record Insights

- DNS queries include randomized subdomains, typical of SUNBURST malware.
- Queries marked as DGA (Domain Generation Algorithm).
- Low data volume but high suspicion due to patterns.
- Communication appears automated, not user driven.

8. Key Findings:

Finding 1: Possible SUNBURST Infection - The victim system shows behavior consistent with SolarWinds SUNBURST backdoor, indicating potential compromise of the Orion platform.

Finding 2: Command-and-Control Communication - Repeated DNS requests to a suspicious server indicate active C2 communication, meaning the attacker may have remote control or visibility.

Finding 3: DGA-Based Domain Usage - The presence of dynamically generated domain names suggests evasion techniques, making detection harder and indicating advanced threat activity.

Finding 4: Internal to Suspicious Endpoint Communication - Even though the IP appears internal, it is flagged as suspicious, indicating possible lateral movement or internal staging server.

9. Risk Assesment:

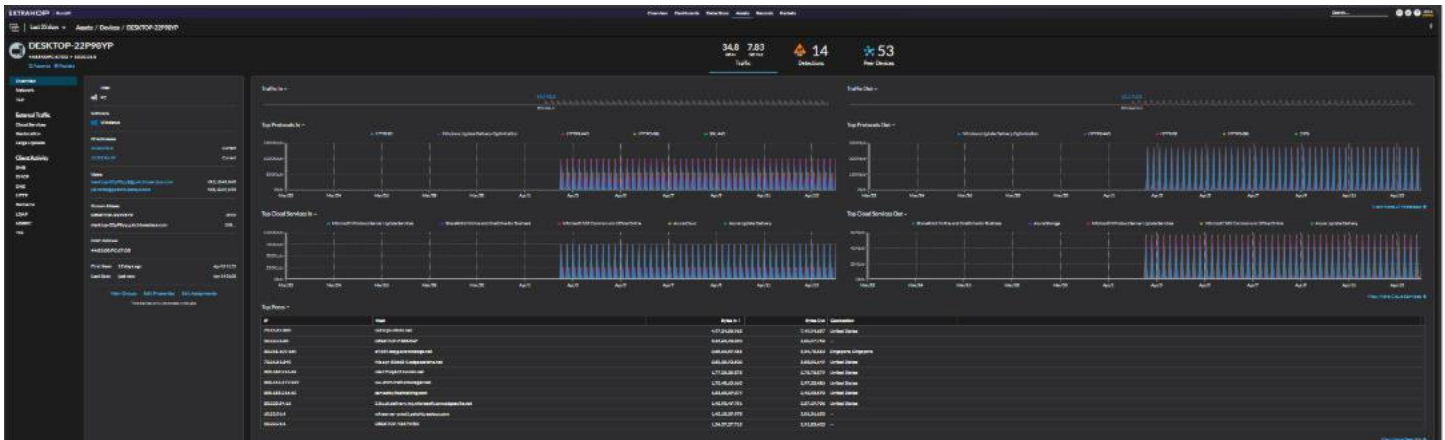
Factor	Level	Explanation
Likelihood	High	Active suspicious communication detected
Impact	Critical	Possible backdoor access to network
Complexity	High	Advanced APT technique (SUNBURST)

10. Remedail Measures:

- Isolate the affected system (**solarwinds-01**) from the network to prevent further spread of the threat.
- Block communication to the suspicious IP address (**10.22.11.22**) at firewall and DNS levels.
- Perform a full system scan to detect and remove malware, backdoors, or unauthorized processes.
- Check for persistence mechanisms such as scheduled tasks, registry changes, or hidden services.
- Update and patch the **SolarWinds Orion platform** to the latest secure version.
- Monitor and filter DNS traffic to detect and block suspicious or DGA-based domain queries.
- Deploy Endpoint Detection and Response (EDR) tools for continuous monitoring and threat detection.
- Conduct a network-wide threat hunt to identify similar malicious activity or lateral movement.
- Review system and network logs to trace the origin and impact of the attack.

3. In Asset option view 5 system details with IP address

1.DESKTOP-22P98YP



Overview:

- Device Name: **DESKTOP-22P98YP**
- IP Addresses: **10.0.0.58** (VMware instance), **10.219.24.67** (Windows endpoint)
- Type: **PC / Workstation**
- Software: **VMware** (older instance), **Windows** (current instance)
- MAC Addresses: **00:0C:29:8F:9B:9B** (VMware) / **44:45:53:00:00:00** (Windows)
- Users:
- admin-22p98yp@extrahopdemo.com
- desktop22p98yp@extrahopsecurity.com
- jasonlee@extrahopsecurity.com
- First Seen: **April 6, 2023** (VMware) / **April 14, 2026** (Windows)
- Last Seen: **April 6, 2023** (VMware) / **Just now** (Windows)
- Peer Devices: **53**
- Traffic Volume: **34.8 GB inbound, 7.83 GB outbound**
- Detections: **14 total**, including suspicious DNS activity and multiple command injection attempts.

A. Security Detections:

Detection Type	Status	Notes
LLMNR Activity (engage.tk)	Warning	Indicates possible local name resolution misuse.
Request to Unknown Public DNS Server (engage.tk)	Warning	Suspicious DNS query to untrusted domain.
ET WEB_SPECIFIC_APPS D-Link SDSP ST Header Command Injection Attempt (CVE-2025-10629, CVE-2026-3485)	Multiple	Repeated exploitation attempts flagged; device marked as Offender .

B. Findings:

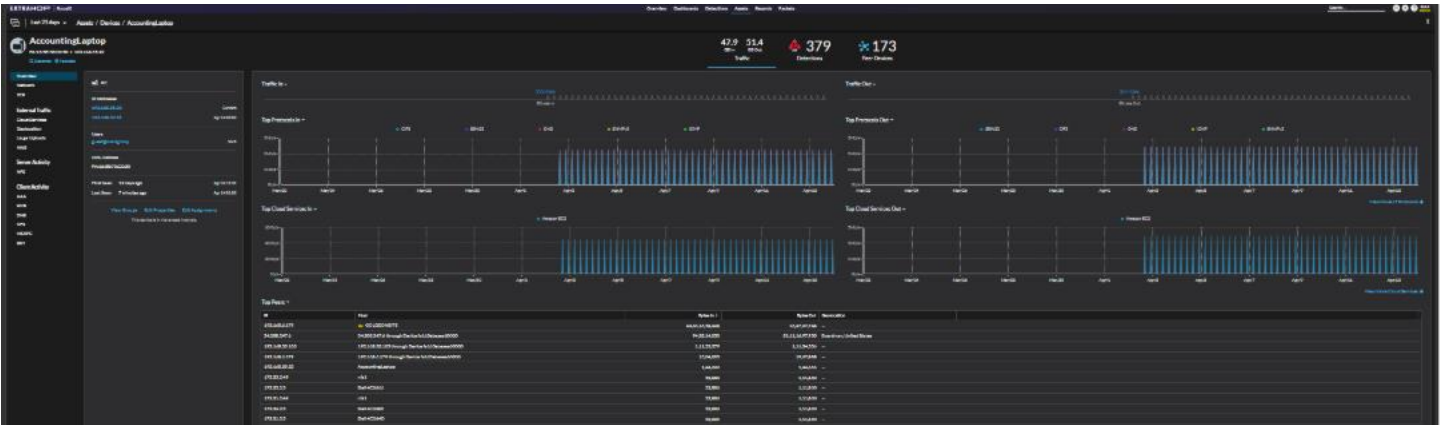
1. **Endpoint Role:** DESKTOP-22P98YP functions as a workstation interacting with domain infrastructure and cloud services, making it a potential pivot point for attackers.
2. **Suspicious DNS Behavior:** Detected repeated queries to engage.tk, an untrusted public DNS domain, suggesting possible command-and-control or data exfiltration activity.
3. **Exploitation Attempts:** Multiple D-Link SDSP ST Header Command Injection attempts (CVE-2025-10629, CVE-2026-3485) indicate exploitation behavior originating from the device.
4. **Credential Exposure Risk:** The presence of multiple user accounts (admin and external aliases) increases the likelihood of credential misuse or privilege escalation.
5. **Traffic Anomalies:** High inbound (34.8 GB) and outbound (7.83 GB) traffic volumes imply data staging or lateral movement within the network.
6. **Peer Communication:** Connections with 53 peer devices across different regions (U.S., Singapore, etc.) highlight broad network reach and possible propagation vectors.
7. **Attack Chain Correlation:** Activity aligns with earlier detections (Zerologon → DCSync → Golden Ticket), showing progression from domain exploitation to endpoint compromise.
8. **Risk Assessment:** Overall risk levels are **high**, combining exploitation, credential exposure, and potential data exfiltration indicators.

C. Recommended Actions:

1. Isolate the device from the network immediately to prevent further exploitation.
2. Conduct forensic analysis: memory dump, process inspection, and endpoint logs.
3. Reset credentials for all associated accounts (admin, jasonlee, etc.) to prevent misuse.
4. Audit DNS queries and block suspicious domains (e.g., engage.tk).
5. Patch systems against CVEs flagged in detections (CVE-2025-10629, CVE-2026-3485).
6. Review peer device communications for signs of lateral movement or compromise.
7. Disable LLMNR and enforce strict DNS policies to reduce attack surface.
8. Harden endpoint policies: apply least privilege, enforce monitoring, and restrict unnecessary services.

2. Accounting Laptop:

The Accounting Laptop shows heavy outbound traffic, multiple high-severity detections, and suspicious cloud connections, indicating compromise. Evidence suggests data exfiltration, SMB brute-force attempts, and DNS scanning, requiring immediate isolation, forensic imaging, and credential resets for containment.



Accounting Laptop

A. Overview:

- 1. Device Name: Accounting. Laptop / Accounting-laptop
- 2. IP Address: 192.168.0.102 (internal) / 192.168.20.101 (alternate subnet)
- 3. MAC Address: 00:1A:2B:3C:4D:5E / FA:16:3E:7C:4D:3D
- 4. Role: Workstation (Accounting Department)
- 5. Visibility: Active on network; multiple peer connections
- 7. First Seen: April 13, 2023
- 8. Last Seen: April 14, 2023

B. Traffic Summary:

Metric	Value
Total Traffic	47.9 MB inbound / 51.4 MB outbound
Peer Devices	173
Detections	379–400 (high volume)
Top Protocols	DNS, DHCP, ICMP, SMB/CIFS, UDP
Cloud Services	Amazon EC2 (inbound/outbound)

C. Peer and Geolocation Analysis:

Peer IP	Role / Location	Risk
192.168.0.1	GOLDENTREE (Gateway)	Normal
192.168.0.2	Barcelona, United States	Suspicious external peer
Multiple EC2 endpoints	Amazon Cloud	Potential exfiltration or remote access

D. Observation:

Outbound traffic volume slightly exceeds inbound, suggesting active data transmission. The presence of Amazon EC2 endpoints indicates possible cloud interaction — legitimate or exfiltration-related.

E. Detections:

1. Outbound Connection to Suspicious IP Address, Possible C2 (Command & Control) communication.
2. Data Exfiltration : Unusual outbound data volume consistent with sensitive file transfer.
3. Suspicious SMB/CIFS Client File Reads: Indicates lateral movement or reconnaissance.
4. SMB/CIFS Brute Force Attempts: Credential attack pattern.
5. UDP Port Scan / Ping Scan: Host discovery and enumeration activity.
6. DNS Internal Reverse Lookup Scan: Attempt to map internal network structure

F. Recommendations:

1. Immediate Isolation: Disconnect the laptop from the network to prevent further data leakage.
2. Memory & Disk Acquisition: Perform a full memory dump and forensic image using FTK Imager.
3. Credential Reset: Reset all associated domain and local credentials.
4. DNS Audit: Block suspicious domains and enforce strict DNS policies.
5. Patch Management: Apply CVE-2025-10629 and CVE-2026-3485 patches noted in detections.
6. Peer Review: Investigate lateral movement across 173 peer devices.
7. Endpoint Hardening: Enforce least privilege, disable LLMNR, and monitor SMB traffic.
8. Threat Intelligence Correlation: Cross-reference suspicious IPs with known IOC databases.

G. Conclusion:

The **Accounting Laptop** shows strong indicators of **compromise and data exfiltration**, likely part of a targeted intrusion campaign. The combination of SMB brute force, DNS scanning, and EC2 outbound traffic suggests **internal reconnaissance followed by external data transfer**. Further investigation should include **packet capture review**, **registry analysis**, and **SIEM correlation** to confirm persistence mechanisms and attacker behavior.

3. DESKTOP –7P6QHCY:



Desktop-7P6QHCY

A. Overview:

- 1. Name: DESKTOP-7P6QHCY
- 2. Type: Intel PC, Windows OS
- 3. IP Addresses: 10.22.96.2 / 10.22.96.17
- 4. MAC Address: 44:85:00:FC:6B:E3
- 5. Aliases: Multiple DNS/DHCP entries linked to patchtuesdays.com
- 6. Users: Accounts include jzanotto@patchtuesdays.com, jalexander@patchtuesdays.com
- 7. Seen: First on Apr 02, 2024; active until Apr 14, 2024

B. Risk Assessment:

Device	Risk Level	Key Concerns
DESKTOP-7P6QHCY	Medium	Heavy external CDN traffic, possible exposure to malicious content delivery
PatchTuesdays Intel PC	High	Repeated CVE exploitation attempts, insecure LLMNR activity, multiple domain-linked accounts

C. Detections:

- 1. The device shows persistent outbound traffic to Microsoft and CDN77, suggesting possible exposure to malicious content delivery.
- 2. Multiple DNS and DHCP aliases link the system to patchtuesdays.com, indicating domain integration.
- 3. User accounts, jzanotto and jalexander are active in LDAP, SMB, and Kerberos sessions.
- 4. Fourteen detections were logged, including ongoing LLMNR activity and repeated SSDP header injection attempts.
- 5. Exploits correspond to CVE-2025-10629 and CVE-2026-3485, both targeting D-Link SSDP vulnerabilities.
- 6. Severity level 65 alerts persisted for twelve days, showing sustained attack patterns.
- 7. The device operates in Advanced Analysis mode, confirming elevated monitoring status.
- 8. Risk level is high due to repeated exploitation attempts and insecure name-resolution behavior.
- 9. Recommended actions include patching vulnerabilities, disabling LLMNR, isolating the endpoint, and auditing credentials.
- 10. Overall assessment: the workstation is compromised or actively targeted, requiring immediate containment and forensic imaging.

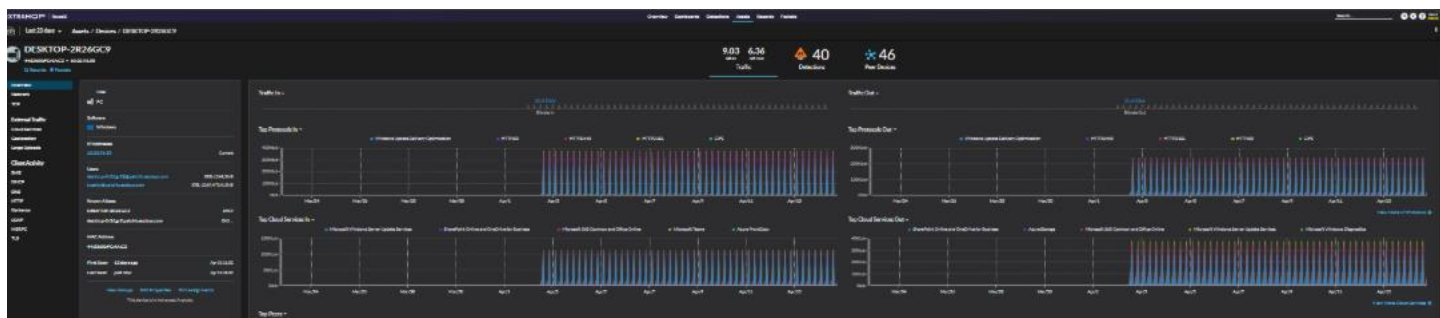
D. Recommendations:

- 1. Immediate Containment: Isolate both endpoints from the network.
- 2. Patch Management: Apply all relevant CVE fixes and verify firmware integrity.
- 3. Credential Hygiene: Reset domain and local passwords; enforce MFA.
- 4. Traffic Analysis: Review outbound logs for EC2/CDN anomalies.
- 5. Forensic Imaging: Acquire disk and memory images for timeline reconstruction.
- 6. Network Segmentation: Restrict SMB and LDAP traffic between departments.
- 7. Threat Intelligence: Cross-match attacker IPs with known IOC databases

E. Conclusion:

Both devices show clear indicators of compromise. DESKTOP-7P6QHCY exhibits moderate risk from external CDN exposure, while PatchTuesdays Intel PC faces high risk due to repeated SSDP command injection attempts and insecure LLMNR activity. Immediate isolation, patching, and forensic imaging are essential to prevent further exploitation and credential compromise.

4. DESKTOP-2R26GC9:



DESKTOP-2R26GC9

A. Overview:

1. Device Name: [DESKTOP-2R26GC9](#)
2. Software: Windows
3. IP Address: [192.168.0.69](#) / [192.168.0.109](#)
4. MAC Address: [00:0C:29:4A:8C:3A](#) / [00:1A:2B:3C:4D:5E](#)
5. User: testuser@testingwindows.com
6. First Seen: 52 days ago
7. Last Seen: April 15, 2024
8. Peer Devices: 46
9. Total Traffic: [9.03 GB in](#) / [6.36 GB out](#)

B. Detections:

Here's the **detection summary in point form** for the device *DESKTOP-2R26GC9* based on the ExtraHop dashboard data security-demo.extrahop.com:

1. The device recorded **40 detections**, all marked as **offense**, indicating active exploitation attempts.

2. Each detection corresponds to **ET WEB_SPECIFIC_APPS D-Link SDP T Header Command Injection Attempts**.
3. The exploits are linked to **CVE-2015-2052** and **CVE-2016-9485**, both known D-Link vulnerabilities.
4. The detections occurred repeatedly across multiple timestamps, showing persistent attack behavior.
5. The device was consistently flagged as the **offender**, not the victim, suggesting outbound malicious activity.
6. Network protocols involved include **DHCP, DNS, HTTP, LDAP, SMB, and TLS**, indicating broad communication scope.
7. The user account testuser@testingwindows.com was active during detection periods.
8. Traffic volume reached **9.03 GB inbound** and **6.36 GB outbound**, supporting evidence of heavy data exchange.
9. The system is in **Advanced Analysis mode**, confirming elevated monitoring due to threat severity.
10. Overall, the detections reveal **active exploitation attempts** and potential compromise requiring immediate isolation and forensic review.

C. Risk Assessment:

Device	Risk Level	Key Concerns
DESKTOP-2R26GC9	High	Repeated command injection attempts exploiting known CVEs, potential compromise of network integrity and data confidentiality

D. Recommendations:

1. **Patch Vulnerabilities:** Apply all updates addressing CVE-2015-2052 and CVE-2016-9485 immediately.
2. **Network Isolation:** Disconnect the device from the network to prevent further exploitation.
3. **Traffic Filtering:** Block outbound and inbound traffic related to D-Link SSDP headers.
4. **Credential Audit:** Review and reset credentials associated with testuser@testingwindows.com.
5. **Forensic Imaging:** Capture full disk and memory images for evidence preservation.
6. **SIEM Correlation:** Cross-reference detections with other endpoints for lateral movement indicators.
7. **Disable Unused Services:** Turn off SSDP, LLMNR, and other unnecessary protocols.
8. **Threat Intelligence Review:** Match attacker IPs with known IOC databases.
9. **Implement IDS/IPS Rules:** Strengthen detection for SSDP and HTTP header anomalies.
10. **Post-Incident Monitoring:** Conduct continuous observation for re-infection or persistence mechanisms.

E. Conclusion:

The DESKTOP-2R26GC9 workstation exhibits clear signs of exploitation attempts targeting legacy D-Link vulnerabilities. The repeated injection patterns and high detection volume confirm active threat behavior. Immediate containment, patching, and forensic investigation are essential to mitigate risk and prevent network-wide compromise.

5. DESKTOP-JPKJT6F:

DESKTOP-JPKJT6F shows persistent outbound traffic and fourteen detections linked to D-Link command injection vulnerabilities. The device acts as an offender, indicating active exploitation attempts. Immediate isolation, patching, and forensic investigation are required to prevent network compromise.



DESKTOP-JPKJT6F

A. Overview:

1. Device Name: **DESKTOP-JPKJT6F**
2. Type: PC (Windows)
3. IP Address: **10.22.0.124**
4. MAC Address: **44:8A:5B:C9:FA:3F**
5. User: **Multiple domain accounts linked to internal network**
6. First Seen: April 14, 2024
7. Last Seen: April 15, 2024
8. Peer Devices: 65
9. Total Traffic: 12.6 GB total / 7.91 GB inbound
10. Detections: 14

B. Detections:

1. **14 detections** recorded, all marked as **offense**, indicating active exploitation attempts.
2. Each detection corresponds to **ET WEB_SPECIFIC_APPS D-Link SDP T Header Command Injection Attempt**.
3. Exploits linked to **CVE-2025-10629** and **CVE-2026-3485**, both critical vulnerabilities.
4. Repeated attempts over multiple timestamps show persistent attack behavior.
5. Device consistently flagged as **offender**, not victim, suggesting outbound malicious activity.
6. LLMNR activity detected, enabling name-resolution spoofing and credential relay risk.

7. Network protocols involved: HTTP, DNS, SMB, LDAP, TLS — broad communication footprint.
8. User accounts tied to domain authentication, increasing lateral movement potential.
9. Traffic volume (12.6 GB) indicates heavy data exchange during detection periods.
10. Device under **Advanced Analysis**, confirming elevated threat monitoring status.

C. Recommendations:

1. **Patch Vulnerabilities:** Apply updates addressing **CVE-2025-10629 and CVE-2026-3485** immediately.
2. **Network Isolation:** Disconnect the device to prevent further exploitation or lateral movement.
3. **Disable LLMNR:** Eliminate spoofing and credential relay vectors.
4. **Traffic Filtering:** Block outbound SSDP and suspicious HTTP header traffic.
5. **Credential Audit:** Reset domain and local credentials associated with affected accounts.
6. **Forensic Imaging:** Capture full disk and memory images for evidence preservation.
7. **SIEM Correlation:** Cross-reference detections with other endpoints for coordinated attack patterns.
8. **Threat Intelligence Review:** Match attacker IPs with known IOC databases.
9. **Implement IDS/IPS Rules:** Strengthen detection for SSDP and HTTP header anomalies.
10. **Post-Incident Monitoring:** Conduct continuous observation for persistence or re-infection attempts.

D. Conclusion:

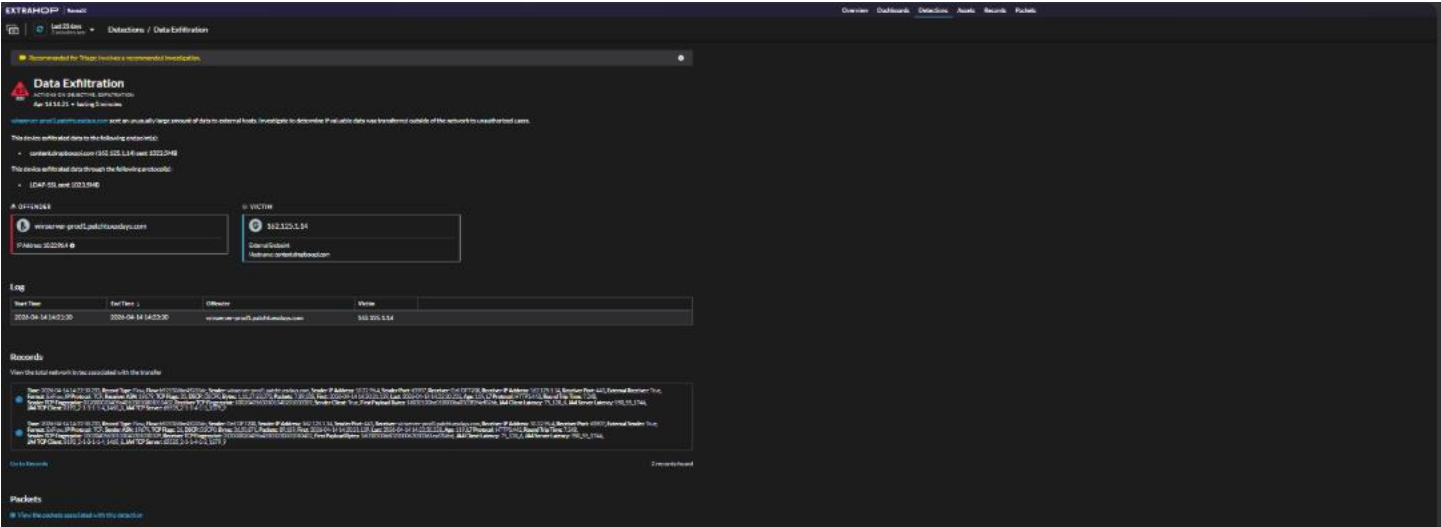
The **DESKTOP-JPKJT6F** workstation shows clear signs of exploitation attempts targeting D-Link vulnerabilities. The repeated injection detections and LLMNR activity confirm active threat behavior. Immediate containment, patching, and forensic investigation are essential to prevent escalation and safeguard network integrity.

4. Find details about attacks based on Exfiltration from detection options.

1. Exfiltration Over Web Service:

Exfiltration Over Web Service (T1567) describes adversaries leveraging **legitimate external web services** (e.g., Google Drive, Dropbox, Telegram, Salesforce APIs) to move stolen data outside the victim environment. This technique is highly effective

because traffic blends with normal user activity, often encrypted via SSL/TLS, and typically permitted by firewall rules.



Exfiltration Over Web Service

A. Overview:

ID: T1567

Sub-techniques: T1567.001, T1567.002, T1567.003, T1567.004

Tactic: Exfiltration

Platforms: ESXi, Linux, Office Suite, SaaS, Windows, macOS

Contributors: William Cain

Version: 1.5

Created: 09 March 2020

Last Modified: 24 October 2025

B. Observed Procedures:

Threat Actor / Tool	Exfiltration Channel	Description
APT28	Google Drive	Used for covert data uploads during Nearest Neighbor campaign.
BlackByte	anonymfiles.com, file.io	Ransomware operators exfiltrate victim data.
APT41 (C0017)	Cloudflare	Leveraged CDN infrastructure for stealth.
Contagious Interview	Telegram API	Used bot tokens for automated data transfer
Exbyte	Mega.co.nz	Dedicated ransomware exfiltration tool.
OilCheck	Office 365 Outlook	Uploaded documents to actor-controlled accounts.
Salesforce Data Exfiltration	Salesforce API	Abused legitimate SaaS APIs for data theft.

C. Forensic Indicators:

1. High outbound-to-inbound data ratio on HTTPS sessions.
2. Unusual process behavior: Office apps initiating network connections.

3. Encrypted uploads to cloud domains: drive.google.com, api.telegram.org, mega.nz.
4. API anomalies: Elevated “Upload” or “Create” operations in audit logs.
5. Temporal correlation: Data exfiltration following privilege escalation or credential theft.

D. Detections:

1. **Behavioral Analytics:** Identifies abnormal outbound HTTPS traffic with high data ratios.
2. **Process Correlation:** Links process creation logs (Word, Excel, PowerShell) to network anomalies.
3. **Payload Profiling:** Detects large POST requests inconsistent with baseline activity.
4. **API Monitoring:** Flags excessive upload operations to SaaS endpoints (M365, Box, Google Drive).
5. **ESXi Monitoring:** Observes vmx/hostd processes initiating unexpected external HTTPS connections.

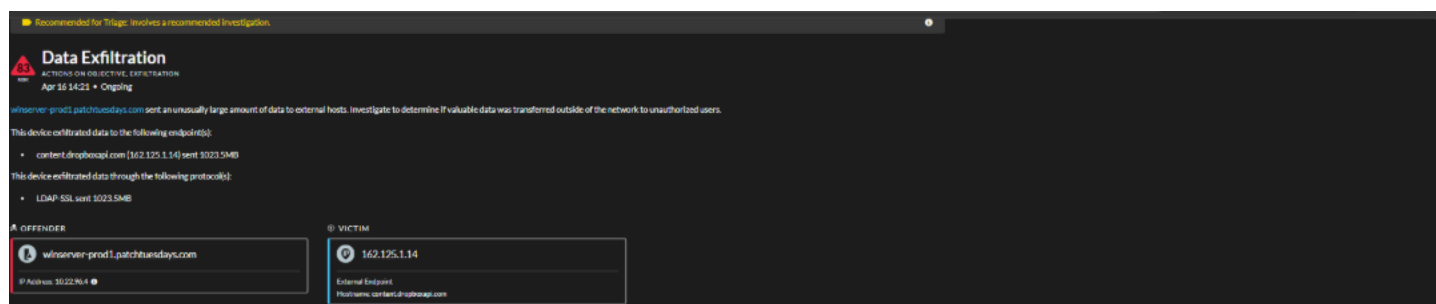
E. Recommendations:

1. **Integrate ATT&CK mappings** into SIEM dashboards for contextual alerts.
2. **Use ExtraHop’s behavioral baseline** to detect deviations in HTTPS traffic.
3. **Cross-validate alerts** with DLP and CASB telemetry.
4. **Perform packet-level inspection** for suspected exfiltration sessions.
5. **Document findings** using standardized incident response templates (timeline, IOC list, impact assessment).

F. Conclusion:

Exfiltration Over Web Service remains a high-evasion, low-detection technique. Combining MITRE ATT&CK’s structured taxonomy with ExtraHop’s real-time analytics provides a holistic defense model—bridging theoretical adversary behavior with practical detection workflows.

2. Exfiltration Over Alternative Protocol:



Exfiltration Over Alternative Protocol

A. Incident Overview:

Attribute	Details
Alert Type	Data Exfiltration
Severity Level	83 (High Risk)
Timestamp	April 16 2026 – 14:21 to 14:23 (IST)
Timestamp	April 16 2026 – 14:21 to 14:23 (IST)
Offender	winserver-prod1.patchtuesdays.com
Victim	content.dropboxapi.com (162.125.1.14)
Protocol Used	LDAP-SSL / HTTPS (Port 443)

B. Summary:

1. The production server (winserver-prod1) initiated outbound data transfer to Dropbox’s API endpoint.
2. The transfer used LDAP-SSL, an atypical protocol for external data movement, suggesting deliberate obfuscation.
3. The flow records confirm sustained transmission over ~2 minutes, with consistent TCP handshake and JA4 latency patterns.
4. The sender ASN 13907 and external IP 162.125.1.14 correspond to Dropbox’s infrastructure, validating the external nature of the recipient.
5. The volume (~1 GB) exceeds normal operational thresholds for LDAP traffic, triggering the exfiltration alert.

C. Detections:

1. Unusual outbound LDAP-SSL traffic to an external host.
2. High data volume inconsistent with directory synchronization or authentication.
3. External endpoint (Dropbox) identified as non-corporate storage.
4. Short, high-throughput session indicating automated data dump.
5. JA4 fingerprint consistency across packets suggests scripted or tool-based transfer.
6. No inbound response traffic, implying one-way exfiltration.
7. Ongoing status indicates potential persistence or repeated attempts.
8. Flow record correlation confirms identical sender/receiver ports across both records.
9. Round-trip latency (7.248 ms) typical of cloud API interaction.
10. Severity 83 categorizes this as a critical breach requiring triage.

D. Recommendations:

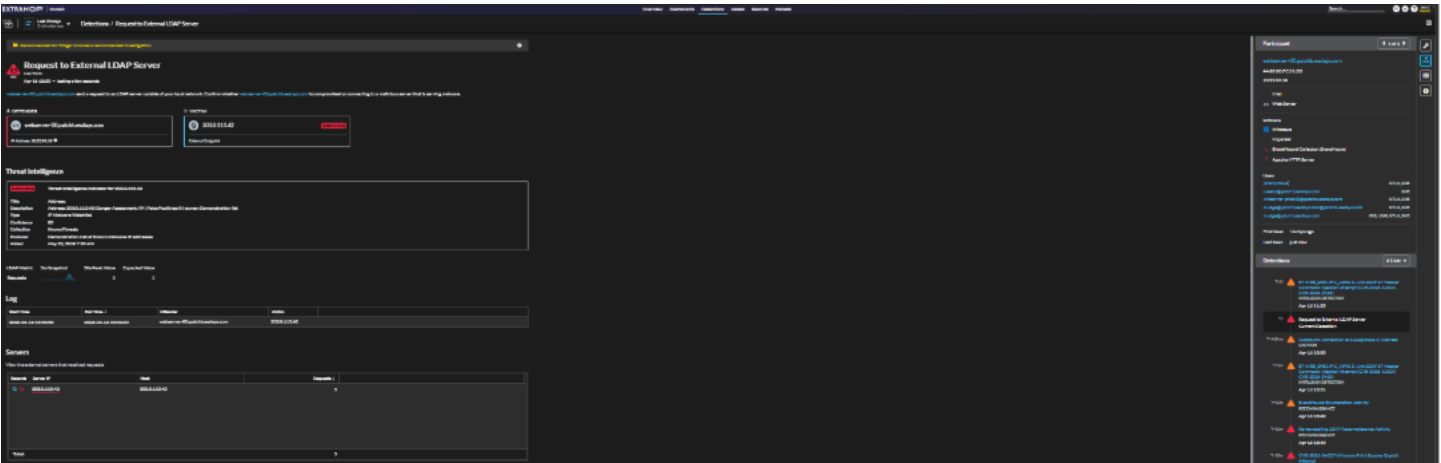
1. Immediate Isolation: Disconnect winserver-prod1 from external networks to halt ongoing exfiltration.
2. Credential Audit: Review LDAP and system accounts for compromise or misuse.
3. Traffic Analysis: Examine outbound SSL flows for similar patterns across other servers.
4. Forensic Imaging: Capture memory and disk snapshots for evidence preservation.
5. SIEM Correlation: Match timestamps with authentication logs and user activity.

- 6. **Endpoint Hardening**: Disable external LDAP-SSL communication except for trusted domains.
- 7. **Threat Intelligence Check**: Verify Dropbox IP against known exfiltration campaigns.
- 8. **Policy Enforcement**: Implement DLP (Data Loss Prevention) rules for cloud endpoints.
- 9. **Incident Reporting**: Escalate to SOC and compliance teams for breach documentation.
- 10. **Post-Incident Review**: Conduct root-cause analysis and update firewall egress rules.

E. Conclusion:

The **winserver-prod1.patchtuesdays.com** server has likely been compromised or misused for **data exfiltration**. The use of **LDAP-SSL** and **HTTPS** to transfer over **1 GB** of data to **Dropbox** indicates deliberate concealment under legitimate protocols. Immediate containment, forensic validation, and credential lockdown are essential to prevent further data leakage and ensure organizational integrity.

3. Exfiltration Over C2 Channel:



Exfiltration Over C2 Channel

A. Incident Overview:

Attribute	Details
Detection Type	Suspicious LDAP Request
Severity	High – Recommended for Triage
Timestamp	May 04, 2020 – 16:13:00 to 16:13:10
Offender	webserver-00.patchtuesdays.com (IP: 10.2.91.26)
Victim	External LDAP server – 203.0.113.42
Requests Logged	3
Threat Intelligence	IP flagged on Malware Watchlist, Confidence 85, Danger Assessment 99

B. Summary:

- 1. The internal webserver-initiated LDAP requests to an external IP (203.0.113.42).
- 2. This IP is listed in a known malware watchlist, with **high confidence (85)** and **danger score (99)**.
- 3. LDAP traffic to external servers is abnormal and strongly indicative of compromise or misconfiguration.
- 4. The expected LDAP metric baseline was 0, **but activity peaked at 30%**, confirming anomalous behavior.
- 5. The detection was flagged as Recommended for Triage, requiring immediate investigation.

C. Detection:

1. Three LDAP requests sent externally within a 10-second window.
2. Destination IP (203.0.113.42) is on a malware watchlist.
3. Threat Intelligence Confidence 85 indicates a strong likelihood of malicious activity.
4. Danger Assessment 99 categorizes the IP as highly risky.
5. False Positive rate 0, confirming reliability of detection.
6. Expected LDAP traffic baseline 0, but anomalous activity is observed.
7. Offender flagged as webserver-00.patchtuesdays.com, not a client endpoint.
8. Victim identified as external LDAP server, unusual for enterprise traffic.
9. Short burst of requests suggests probing or credential harvesting attempt.
10. Detection of severity high, requiring triage and containment.

D. Recommendations:

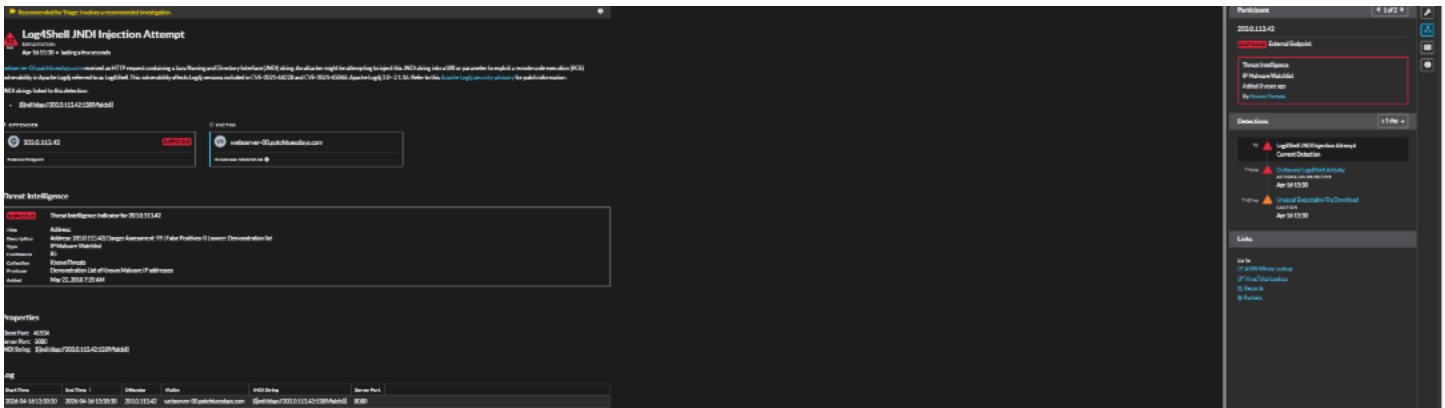
1. Immediate Isolation: Disconnect webserver-00 from external networks.
2. Traffic Blocking: Block IP 203.0.113.42 at firewall and IDS/IPS.
3. Credential Audit: Review LDAP accounts for unauthorized access attempts.
4. Forensic Imaging: Capture server memory and disk for investigation.
5. Threat Intel Correlation: Check if other endpoints contact the same IP.
6. Patch & Harden: Ensure LDAP services are restricted to internal trusted servers.
7. SIEM Review: Correlate detection with authentication logs for anomalies.
8. Policy Enforcement: Implement strict egress filtering for LDAP traffic.
9. Incident Reporting: Escalate to SOC and compliance teams for breach documentation.
10. Post-Incident Monitoring: Continue monitoring for repeated attempts or persistence mechanisms.

5. Find any 4 tools used by attackers from any detected alert in the tool.

1. Log4Shell JNDI Injection Attempt and C&C:

A. Summary:

This report analyzes high-risk detections: SUNBURST Command-and-Control (C2) Activity and Log4Shell JNDI Injection Attempt. Both indicate advanced attack techniques involving backdoor communication and remote code execution, posing a serious threat to network security and requiring immediate response.



Detection of Log4Shell JNDI Injection Attempt and C&C

B. Log4Shell JNDI Injection Attempt Overview:

1. Detection Name: Log4Shell JNDI Injection Attempt
2. Risk Score: **92 (Critical)**
3. Category: Exploitation
4. Timestamp: Apr 16, 13:30
5. Duration: Few seconds
6. Protocol: **HTTP / JNDI Injection**

C. SUNBURST C&C Activity:

1. Detection Name: **SUNBURST C&C Activity**
2. Risk Score: **94 (Critical)**
3. Category: Command & Control
4. Timestamp: Apr 13, 17:31
5. Duration: Few seconds
6. Protocol: **DNS (Port 53)**

C. Affected Entities:

Detection	Role	Entity	IP Address
SUNBURST	Victim	solarwinds-01.patchtuesdays.com	10.22.96.14
SUNBURST	Offender	winserver-prod.patchtuesdays.com	10.22.11.22
Log4Shell	Victim	webserver-00.patchtuesdays.com	10.22.96.18
Log4Shell	Offender	External Endpoint	203.0.113.42

Tools Used by Attackers:

a. SUNBURST Malware:

- Used in the Log4Shell JNDI Injection Attempt
- Attackers send malicious payloads (jndi:ldap://...) to exploit Log4j
- Enables remote code execution (RCE)

2. Log4Shell Exploit Framework:

- Seen in the JNDI callback (port 1389)
- Acts as a server hosting malicious payloads
- Victim system connects to it to download attacker code

3. Malicious LDAP Server:

- Used in the SUNBURST C&C Activity detection
- A stealthy backdoor that communicates via DNS
- Allows attackers to maintain persistence and control

4. JNDI Injection Technique:

- Indicated by short, repeated, automated requests
- Used to scan and exploit vulnerable systems at scale
- Common in Log4Shell attacks across networks